

Assurance Assignment: Hand-in

Role: SAMM specialist

Francesco Maria Fuligni | Group 13

1. Core

Security Testing (Verification)

Dedicated security test cases for known-risk areas, run regularly. Audit: authorization, path traversal, login throttling and link access. Existing link tests checked HTTP 200/PDF without authentication for an issued link; HTTP 404/no PDF for random, last-character-flipped, plus-one and all-zero unissued links; and separation of two users' documents and watermark secrets. Pytest runs in CI on PRs to `main` and pushes to `main/feat/**`.

Improvement

The manual SHA-1(s1) check became an automated regression:

```
GET /api/get-version/640d87e741e6aa4c669a82a4cd304787960513ab
```

Result: HTTP 404, no PDF. Four negative-link cases gained assertions excluding both users' secrets, recipients and filenames from responses. On 30 September, the focused module passed all seven cases and Ruff. Commit: `fbae18a`.

Scorecard

Level 1	Level 2 – assigned	Level 3
Security tested only incidentally.	Dedicated security test cases for known-risk areas, run regularly.	Systematic testing, negative cases and tracked coverage.

Evidence: Dedicated risk-based tests run regularly in CI; the new checks strengthen that coverage. Systematic coverage tracking is missing. SQLite and `toy-eof` fixtures limit the results to the tested cases.

2. Further Work

Secure Build (Implementation)

Builds automated and reproducible; dependencies pinned. Before improvement: no Docker build in CI; Docker ignored the local lockfile. Observed mismatch: image `cryptography 50.0.2`, lockfile `50.0.1`. Manual build/import and Compose configuration validation passed.

Improvement

CI image build and `import rmap`; tracked requirements pinning 26 Python distributions; shared runtime versions for Docker and pytest; base-image digest pinning; CI dependency-drift check. Clean build passed; all 26 installed versions matched; `pip check` and `import rmap` passed. Recorded CI run `36756093546`: lock check, Docker and Ruff passed; pytest 368 passed, 11 skipped, 2 xfailed. Commits: `8a1073f`, `f0cd7ae`, `f7e50c3`.

Scorecard

Level 1	Level 2 – assigned	Level 3
Manual, inconsistent builds.	Automated, reproducible builds; pinned dependencies.	Automated security checks as a build-pipeline gate.

Evidence: Repeatable CI build/import, exact tracked Python versions and passing drift/version checks support Level 2 for the server/Python build. System packages remain unpinned. Full-stack startup was not tested. No dedicated vulnerability scan or confirmed required merge check establishes Level 3.

3. Hours

	Reading	Audit	Improvement
Core	1 h	3 h	1 h
Further Work	30 min	3 h	1 h

Audit includes scorecards, evidence review and write-up; — means no separate reading entry in Notion.

Total: approximately 10 hours.